

PUBLIC PROFESSIONAL BRIEF

# Docker Benchmark Results and Hardening Brief

Professional interpretation of Docker Bench warnings and container hardening priorities for OT-supporting infrastructure.

|                       |                                                                                 |
|-----------------------|---------------------------------------------------------------------------------|
| Prepared by           | Bernard Boakye Appiah                                                           |
| Scenario organization | NorthGrid Energy - fictional Ontario critical infrastructure operator           |
| Document type         | Container hardening evidence brief                                              |
| Public disclosure     | All content is sanitized and based on a fictional security assessment scenario. |
| Date                  | July 2026                                                                       |

## Selected assessment metrics

|                           |                |               |
|---------------------------|----------------|---------------|
| 137<br>Docker Bench tests | 21<br>Warnings | 0<br>Failures |
|---------------------------|----------------|---------------|

**Public disclosure note:** NorthGrid Energy is a fictional scenario used to demonstrate professional cybersecurity assessment, governance, and risk communication skills. The content is sanitized for public review and does not contain proprietary or private operational data.

OVERVIEW

# Purpose and Executive Summary

This brief summarizes the Docker Bench portion of the NorthGrid Energy assessment. The goal was to review container-host security posture and explain which benchmark warnings would matter if containerized tools were used for OT management, monitoring, or security operations.

The Docker Bench assessment produced 21 warnings and no failures. In a public professional brief, the important result is not simply the count; it is the risk interpretation. The highest-value findings relate to container network restrictions, user namespace isolation, Docker command authorization, centralized logging, and limiting privilege escalation.

|                        |                |               |
|------------------------|----------------|---------------|
| 137<br>Tests performed | 40<br>Checks   | 19<br>Score   |
| 19<br>Passes           | 21<br>Warnings | 0<br>Failures |

SCOPE

# Assessment Context

| Item        | Public-view detail                                                                                                                                                            |
|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Tool        | Docker Bench for Security, based on CIS Docker Benchmark guidance.                                                                                                            |
| Environment | Docker Desktop Linux backend used to assess local container security posture.                                                                                                 |
| Purpose     | Identify benchmark warnings that would matter in a critical infrastructure or OT-supporting deployment.                                                                       |
| Limitations | Some file/service checks were not applicable because of the local Docker Desktop environment. Section 5 runtime checks were skipped when no relevant containers were running. |

EVIDENCE SUMMARY

# Key Docker Bench Findings

| Finding ID | Benchmark theme                                                    | Why it matters for OT-supporting containers                                                                                                                                 | Priority |
|------------|--------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| 2.2        | Restrict network traffic between containers on the default bridge. | Unrestricted container-to-container traffic can help an attacker pivot from one compromised service toward monitoring, historian, or EMS-supporting tools on the same host. | High     |
| 2.9        | Enable user namespace support.                                     | Weak namespace isolation can increase impact if a container process attempts host-level interaction.                                                                        | High     |
| 2.12       | Enable authorization for Docker client commands.                   | Without authorization controls, unauthorized users or processes may create privileged containers, mount host paths, or modify services.                                     | High     |
| 2.13       | Configure centralized and remote logging.                          | Local-only Docker logs reduce SOC visibility and weaken investigation during an incident.                                                                                   | High     |
| 2.14       | Restrict containers from acquiring new privileges.                 | If containers can acquire new privileges, an application compromise can become a broader host security issue.                                                               | High     |
| 2.15       | Enable live restore.                                               | A Docker daemon restart may disrupt containerized services if live restore is not configured.                                                                               | Medium   |
| 4.5        | Enable Docker Content Trust.                                       | Unsigned or unverified images increase software supply chain risk.                                                                                                          | Medium   |

| Finding ID | Benchmark theme                                   | Why it matters for OT-supporting containers                                | Priority |
|------------|---------------------------------------------------|----------------------------------------------------------------------------|----------|
| 4.6        | Add HEALTHCHECK instructions to container images. | Missing health checks reduce operational visibility into container status. | Medium   |

## RISK ANALYSIS

# Security Interpretation

Docker Bench warnings should be interpreted by deployment context. A local lab or development workstation may have acceptable exceptions, but an OT management or monitoring host requires stricter controls because compromise could affect visibility, recovery, or operational support.

| Risk category          | Relevant warnings | Risk explanation                                                                                                          |
|------------------------|-------------------|---------------------------------------------------------------------------------------------------------------------------|
| Network segmentation   | 2.2               | A compromised container should not be able to freely communicate with other containers or host services.                  |
| Privilege containment  | 2.9, 2.14         | Namespace support and no-new-privileges settings reduce the chance that a container compromise becomes a host compromise. |
| Administrative control | 2.12, 3.15        | Docker socket and client command access must be tightly controlled because Docker can create powerful host interactions.  |
| Logging and detection  | 2.13              | Centralized logs are necessary for SOC triage, incident reconstruction, and compliance evidence.                          |
| Supply chain assurance | 4.5, 4.6          | Image trust and health checks help reduce unverified image use and improve runtime observability.                         |

## CONTROLS

# Recommended Hardened Configuration Direction

The recommended direction is to treat container hosts like production infrastructure, not temporary tooling. Controls should be enforced through configuration standards, change control, log forwarding, and image governance.

- 1 Create dedicated Docker networks for application groups and restrict default bridge traffic.
- 2 Enable user namespace remapping where application compatibility allows it, and document exceptions where it does not.
- 3 Run containers with least privilege, avoid privileged mode, use read-only mounts where possible, and apply no-new-privileges.
- 4 Restrict Docker socket access to approved administrators and monitor Docker command activity.
- 5 Forward Docker daemon and container logs to centralized logging or SIEM tooling.
- 6 Use signed or verified base images, pin image versions, and rebuild images when security updates are available.
- 7 Add HEALTHCHECK instructions to container images that support operational services.

## CRITICAL INFRASTRUCTURE CONTEXT

# OT Exception Handling

Some OT-supporting applications may require settings that fail a generic benchmark. When that happens, the correct professional response is not to hide the warning. The exception should be documented with business justification, system owner approval, compensating controls, monitoring, and an expiry or review date.

| Exception example                                            | Compensating control                                                                                            |
|--------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|
| Application requires host namespace or elevated permissions. | Limit host placement, isolate network paths, monitor process and Docker events, and require OT change approval. |
| Vendor image lacks HEALTHCHECK.                              | Add external health monitoring, vendor escalation requirement, and scheduled image review.                      |
| Content trust not supported for a vendor image.              | Use vendor hash validation, private registry controls, and staged testing before production use.                |
| Central logging delayed by operational constraints.          | Temporarily collect local logs with retention and schedule SIEM onboarding as a remediation item.               |

RECOMMENDATIONS

Action Plan

| Timeline   | Action                                                                               | Outcome                                                     |
|------------|--------------------------------------------------------------------------------------|-------------------------------------------------------------|
| 0-30 days  | Restrict Docker admin access, review socket ownership, and centralize Docker logs.   | Reduces immediate privilege and visibility risk.            |
| 30-60 days | Implement network isolation, no-new-privileges, and image version pinning.           | Improves containment and repeatability.                     |
| 60-90 days | Introduce image trust/verification and health checks for production-like containers. | Improves supply chain assurance and operational monitoring. |
| Quarterly  | Re-run Docker Bench and document exceptions with owners and remediation dates.       | Turns benchmark output into a governance cycle.             |